

1. Behind the mountain

behind the mountain

by teebow1e

995 4

Công ty A đang có dự định mở một kênh thông tin nội bộ cho các thành viên, tuy nhiên, server của họ đã không cấu hình Firewall một cách hợp lý. Tổ giám sát ngay khi phát hiện lưu lượng truy cập lạ gia tăng đã ngay lập tức bật packet capture để lưu lại lưu lượng mạng.

Tuy nhiên, tổ giám sát lại không có chuyên gia nào đủ kinh nghiệm để phân tích file packet capture này. Liệu bạn có thể?

https://drive.google.com/file/d/1K6P1yKOTE50wCDU-6Ah7v_jsfr_3xXRE/view?usp=sharing

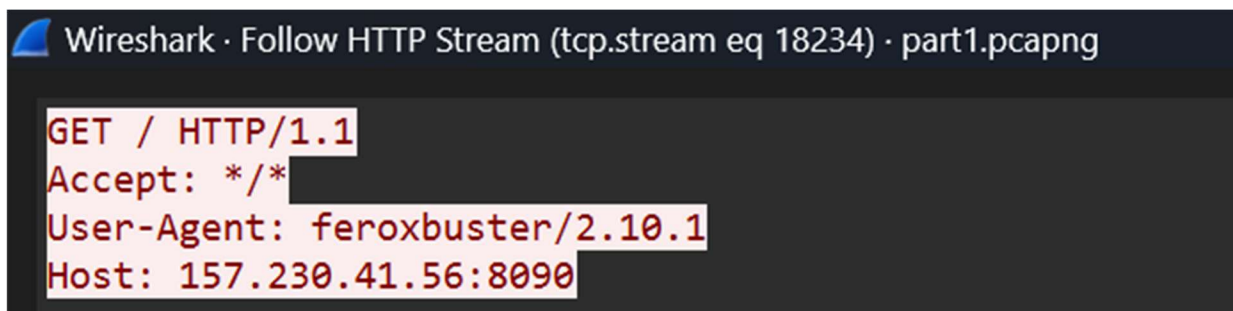
You've solved this challenge!

Challenge cung cấp 1 file lưu lượng mạng part1.pcapng

Phân tích qua thì các gói mạng được truyền chủ yếu qua giao thức TCP (89,3%), trong đó truyền qua HTTP là 34,8%

Transmission Control Protocol	89.3
Transport Layer Security	0.1
SSH Protocol	2.1
Malformed Packet	0.0
Session Initiation Protocol	0.0
Remote Procedure Call	0.0
Portmap	0.0
NetBIOS Session Service	0.0
SMB2 (Server Message Block Protocol version 2)	0.0
SMB (Server Message Block Protocol)	0.0
Microsoft Delivery Optimization	0.0
Hypertext Transfer Protocol	34.8
Portable Network Graphics	0.0
MIME Multipart Media Encapsulation	0.0
Media Type	0.0
Line-based text data	17.3
HTML Form URL Encoded	0.0
eXtensible Markup Language	0.0
CompuServe GIF	0.0
General Inter-ORB Protocol	0.0
Distributed Computing Environment / Remote Procedure Call (DCE/RPC)	0.0
Internet Control Message Protocol	0.0
Data	2.6
Address Resolution Protocol	0.1

Sau khi xem qua conversation thì em thấy rằng rất có thể IP nội bộ là 116.96.45.164, có dấu hiệu gửi request đến IP 157.230.41.56, ngoài ra còn có request HTTP



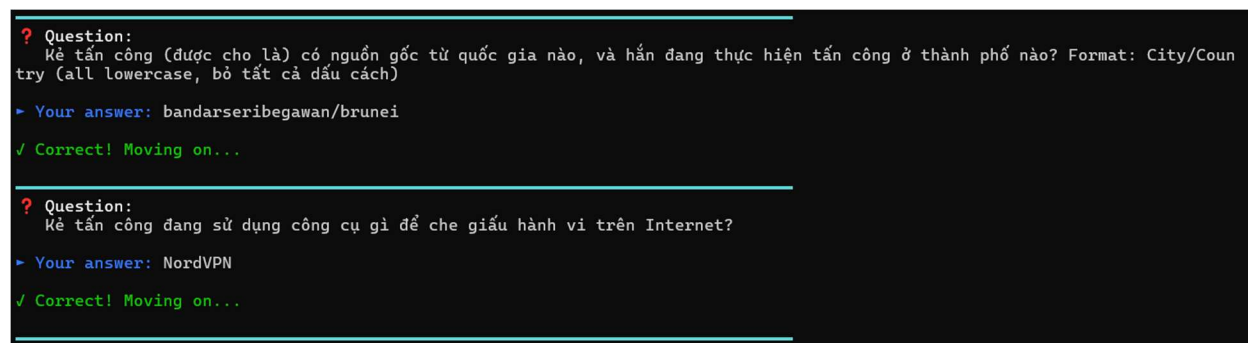
Trong đó feroxbuster là tool brute-force directory → dấu hiệu scan web.

→ Em lọc với filter ip.addr==157.230.41.56

No.	Time	Source	Destination	Protocol	Length	Info
1	2024-03-30 11:50:05.567558	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
2	2024-03-30 11:50:05.567616	157.230.41.56	116.96.45.164	TCP	54	22 → 27364 [ACK] Seq=1 Ack=51 Win=63449 Len=0
3	2024-03-30 11:50:05.574210	157.230.41.56	116.96.45.164	UDP	52	22 → 52840 Len=10
4	2024-03-30 11:50:05.584169	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
5	2024-03-30 11:50:05.594891	157.230.41.56	116.96.45.164	UDP	148	22 → 52840 Len=106
6	2024-03-30 11:50:05.596746	116.96.45.164	157.230.41.56	UDP	119	52840 → 22 Len=77
7	2024-03-30 11:50:05.600215	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
8	2024-03-30 11:50:05.600268	157.230.41.56	116.96.45.164	TCP	54	22 → 27364 [ACK] Seq=1 Ack=151 Win=63349 Len=0
9	2024-03-30 11:50:05.616138	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
10	2024-03-30 11:50:05.621006	157.230.41.56	116.96.45.164	UDP	53	22 → 52840 Len=11
11	2024-03-30 11:50:05.631518	157.230.41.56	116.96.45.164	UDP	1247	22 → 52840 Len=1205
12	2024-03-30 11:50:05.633148	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
13	2024-03-30 11:50:05.633201	157.230.41.56	116.96.45.164	TCP	54	22 → 27364 [ACK] Seq=1 Ack=251 Win=63249 Len=0
14	2024-03-30 11:50:05.643673	116.96.45.164	157.230.41.56	UDP	112	52840 → 22 Len=70
15	2024-03-30 11:50:05.646500	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
16	2024-03-30 11:50:05.661983	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
17	2024-03-30 11:50:05.662060	157.230.41.56	116.96.45.164	TCP	54	22 → 27364 [ACK] Seq=1 Ack=351 Win=63149 Len=0
18	2024-03-30 11:50:05.667921	157.230.41.56	116.96.45.164	UDP	53	22 → 52840 Len=11
19	2024-03-30 11:50:05.677651	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
20	2024-03-30 11:50:05.679670	116.96.45.164	157.230.41.56	UDP	111	52840 → 22 Len=69
21	2024-03-30 11:50:05.694169	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
22	2024-03-30 11:50:05.694237	157.230.41.56	116.96.45.164	TCP	54	22 → 27364 [ACK] Seq=1 Ack=451 Win=63049 Len=0

Thấy được thời điểm bắt đầu của cuộc tấn công là thời điểm khi gói mạng đầu tiên xuất hiện

→ Đáp án câu 1: 11am;30-03-2024 GMT+7



Câu hỏi thứ 2 và thứ 3 hỏi về nguồn gốc của Attacker và công cụ đã được sử dụng để che giấu hành vi (loại VPN nào đã được sử dụng).

Lọc các http request em thấy rất nhiều các gói mạng GET / POST gửi lên từ địa chỉ IP 45.134.190.42 tới server, tra nguồn gốc IP này với ip2location em có được đáp án.

☒ IP Address	45.134.190.42
☐ Anonymous Proxy	Yes
☐ Proxy Country	 Brunei Darussalam [BN]
☐ Proxy Region	Brunei-Muara
☐ Proxy City	Bandar Seri Begawan
☐ Proxy ISP	PacketHub S.A.
☐ Proxy Domain	nordvpn.com
☐ Proxy Usage Type	(DCH) Data Center/Web Hosting/Transit
☐ Proxy Type	VPN
☐ Proxy ASN	AS212238 DataCamp Limited
☐ Threat	-
☐ Last Seen	1 day ago
☐ Provider	NordVPN
☐ Fraud Score	99

➔ Đáp án câu 2: bandarseribegawan/brunei

➔ Đáp án câu 3: NordVPN

? Question:
Server đang mở những cổng nào? (Format: viết các cổng từ nhỏ đến lớn, ngăn cách bằng dấu phẩy, chỉ tính các cổng từ 1-10000)

Câu hỏi thứ 4 hỏi về những cổng đang mở, vì cổng đang mở khi có syn và ack (gửi và nhận request) từ IP server 157.230.41.56, ngoài ra vì đề còn yêu cầu chỉ tính các cổng từ 1 đến 10000 nên

➔ sort với ip.src==157.230.41.56 && tcp.flags.syn == 1 && tcp.flags.ack == 1 && tcp.srport <= 10000

No.	Time	Source	Destination	Protocol	Length	Info
29074	2024-03-30 12:07:07.022418	157.230.41.56	45.134.190.42	TCP	66	135 → 26558 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256
56077	2024-03-30 12:23:09.391631	157.230.41.56	45.134.190.42	TCP	66	135 → 31164 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256
55931	2024-03-30 12:23:03.006724	157.230.41.56	45.134.190.42	TCP	66	135 → 31206 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256
55974	2024-03-30 12:23:03.220341	157.230.41.56	45.134.190.42	TCP	66	135 → 31208 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256
17059	2024-03-30 11:59:20.896511	157.230.41.56	45.134.190.42	TCP	66	135 → 5172 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 S
29076	2024-03-30 12:07:07.022807	157.230.41.56	45.134.190.42	TCP	66	139 → 26519 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 S
55928	2024-03-30 12:23:03.006649	157.230.41.56	45.134.190.42	TCP	66	139 → 31160 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 S
55969	2024-03-30 12:23:03.220146	157.230.41.56	45.134.190.42	TCP	66	139 → 31174 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 S
56083	2024-03-30 12:23:09.392019	157.230.41.56	45.134.190.42	TCP	66	139 → 31186 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 S
17046	2024-03-30 11:59:20.896100	157.230.41.56	45.134.190.42	TCP	66	139 → 5138 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SA
38103	2024-03-30 12:12:54.587334	157.230.41.56	52.142.239.0	TCP	66	22 → 13863 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SAC
49922	2024-03-30 12:20:53.051331	157.230.41.56	116.96.45.164	TCP	66	22 → 16436 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SAC
10045	2024-03-30 11:55:11.607434	157.230.41.56	167.94.145.28	TCP	58	22 → 17137 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SAC
47711	2024-03-30 12:19:08.591471	157.230.41.56	5.38.177.178	TCP	58	22 → 26649 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SAC
29103	2024-03-30 12:07:07.023407	157.230.41.56	45.134.190.42	TCP	66	22 → 26691 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SAC
55930	2024-03-30 12:23:03.006664	157.230.41.56	45.134.190.42	TCP	66	22 → 31132 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SAC
61010	2024-03-30 12:27:02.680289	157.230.41.56	45.134.190.42	TCP	66	22 → 31140 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SAC
55977	2024-03-30 12:23:03.220435	157.230.41.56	45.134.190.42	TCP	66	22 → 31146 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SAC
56365	2024-03-30 12:23:14.651863	157.230.41.56	45.134.190.42	TCP	66	22 → 31147 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SAC
56383	2024-03-30 12:23:14.824192	157.230.41.56	45.134.190.42	TCP	66	22 → 31151 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SAC
57749	2024-03-30 12:25:42.767114	157.230.41.56	45.134.190.42	TCP	66	22 → 31164 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SAC
57733	2024-03-30 12:25:42.766750	157.230.41.56	45.134.190.42	TCP	66	22 → 31182 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SAC

➔ Đáp án câu 4: 22,135,139,445,5040,5357,7680,8001,8090

? Question:
Webserver đang được serve tại cổng nào?

Từ bộ lọc đã áp dụng ở trên, Statistics Conversation cho thấy packets qua cổng 8090 chiếm đa số (tầm 80-90%)

➔ Đáp án câu 5: 8090

? Question:
Sau khi thực hiện quét cổng, kẻ tấn công đã tiến hành quét tự động bằng một công cụ, User-Agent của công cụ này là gì?

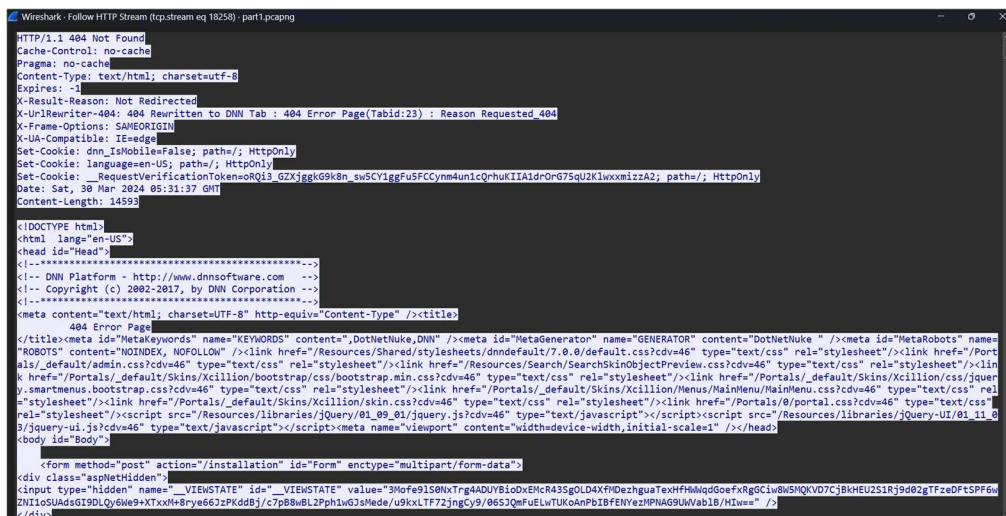
Khi giải những câu trên, em đã tìm được User-Agent của công cụ này

Wireshark · Follow HTTP Stream (tcp.stream eq 18234) · part1.pcapng

```
GET / HTTP/1.1
Accept: */*
User-Agent: feroxbuster/2.10.1
Host: 157.230.41.56:8090
```

➔ Đáp án câu 6: feroxbuster/2.10.1

? Question:
Tên của dịch vụ đang chạy ở Webserver là gì? Dịch vụ này có 1 CVE được biết đến rộng rãi, bạn có thể nêu tên được không? (Format: ServiceName_CVE. Ví dụ: Atlassian Confluence_CVE-2023-22527)



```
HTTP/1.1 404 Not Found
Cache-Control: no-cache
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Expires: -1
X-Result-Reason: Not Redirected
X-Url-Writer: 404: 404 Rewritten to DNN Tab : 404 Error Page(TabId:23) : Reason Requested 404
X-Frame-Options: SAMEORIGIN
X-UA-Compatible: IE=edge
Set-Cookie: dnn_IsMobile=False; path=/; HttpOnly
Set-Cookie: language=en-US; path=/; HttpOnly
Set-Cookie: RequestVerificationToken=RQ13_QZXjgkG9K8n-sw5CY1ggFu5FCYnm4un1Q-huKIIAIdrOrG75qU2K1uxxi2A2; path=/; HttpOnly
Date: Sat, 30 Mar 2024 05:31:37 GMT
Content-Length: 14593

<!DOCTYPE html>
<html lang="en-US">
<head id="Head">
<!-- ***** -->
<!-- DNN Platform - http://www.dnnsoftware.com -->
<!-- Copyright (c) 2002-2017, by DNN Corporation -->
<!-- ***** -->
<meta content="text/html; charset=UTF-8" http-equiv="Content-Type" /><title>
404 Error Page
</title><meta id="MetaKeywords" name="KEYWORDS" content="DotNetNuke,DNN" /><meta id="MetaGenerator" name="GENERATOR" content="DotNetNuke" /><meta id="MetaRobots" name="ROBOTS" content="NOINDEX, NOFOLLOW" /><link href="/Resources/Shared/stylesheets/dnndefault/7.0.0/default.css?cdv=46" type="text/css" rel="stylesheet" /><link href="/Portals/_default/admin.css?cdv=46" type="text/css" rel="stylesheet" /><link href="/Resources/Search/SearchSkinObjectPreview.css?cdv=46" type="text/css" rel="stylesheet" /><link href="/Portals/_default/Skins/Xcillion/bootstrap/css/bootstrap.min.css?cdv=46" type="text/css" rel="stylesheet" /><link href="/Portals/_default/Skins/Xcillion/css/jquery.smartmenus.bootstrap.css?cdv=46" type="text/css" rel="stylesheet" /><link href="/Portals/_default/Skins/Xcillion/Menu/MainMenu/MainMenu.css?cdv=46" type="text/css" rel="stylesheet" /><link href="/Portals/_default/Skins/Xcillion/skin.css?cdv=46" type="text/css" rel="stylesheet" /><link href="/Portals/_default/Skins/Xcillion/portal.css?cdv=46" type="text/css" rel="stylesheet" /><script src="/Resources/libraries/jquery/01_00_01/jquery.js?cdv=46" type="text/javascript"></script><script src="/Resources/libraries/jquery-ui/01_11_03/jquery-ui.js?cdv=46" type="text/javascript"></script><meta name="viewport" content="width=device-width,initial-scale=1" /></head>
<body id="Body">
<form method="post" action="/Installation" id="Form" enctype="multipart/form-data">
<div class="aspNetHidden">
<input type="hidden" name="_VIEWSTATE" id="_VIEWSTATE" value="3Nofe9150NXTg4ADUY8ioDxEKcR43SgOLD4XFpDezhgutaXHFHwQdGoeFxrG5C1w8W5MQKVD07CjBkHEU251Rj9d02gTFzeDfSPF6wZNI0sUadsGI9DLQy6we9XTxxH48rye66Z2PKd8j/c7pB8wBL2Pph1wG3Hede/u9kxLTf72jngCy9/06SjQmFuELwTUKoAnPbIBFENyZzHPNAG9UwVab1B/Hlw==" />
</div>
```

Follow HTTP Stream của 1 gói mạng là phản hồi trả về từ server em thấy được tên dịch vụ DotNetNuke, và gợi ý của bài là 1 CVE được BIẾT ĐẾN RỘNG RÃI

➔ Đáp án câu 7: DotNetNuke_CVE-2017-9822

Và đó cũng là câu hỏi cuối của challenge.